Milestone 6 – Member 2 Evidence

A. Security controls checklist

#	Control	How it was checked	Result
1	Private database	aws rds describe-db-instances → PubliclyAccessible	Pass – False; storage encryption enabled
2	S3 not public	get-public-access-block on the app bucket and the Terraform state bucket	Pass – all four settings True on both
3	Role-based S3 access	API task definition taskRoleArn	Pass – socialops-dev-api-task IAM role, no access keys
4	Secrets Manager	API task definition secrets	Pass – DATABASE_URL injected from Secrets Manager
5	No secrets or state in git	git ls-files and .gitignore	Pass – only .env.example tracked; state in private S3 bucket
6	Secrets not visible in demo	Agreed with presenter	Pass – no .env, secret values or AWS keys on screen

A1. Private database



Figure A1a – RDS socialops-dev: PubliclyAccessible = False, in the private socialops-dev subnet group.

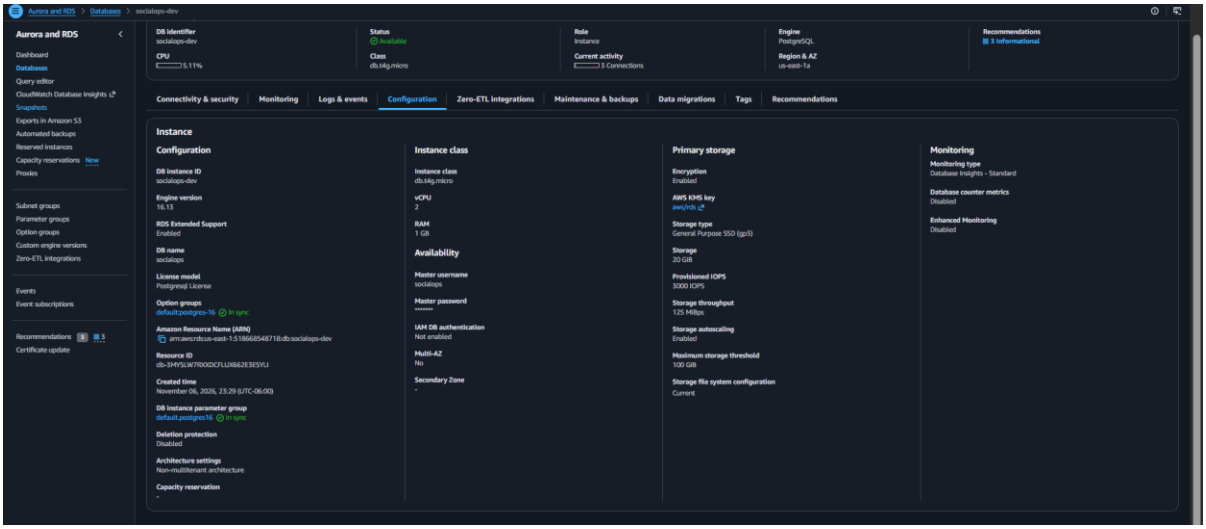


Figure A1b – RDS configuration: storage encryption enabled (aws/rds KMS key), master password hidden.

A2. S3 buckets block public access

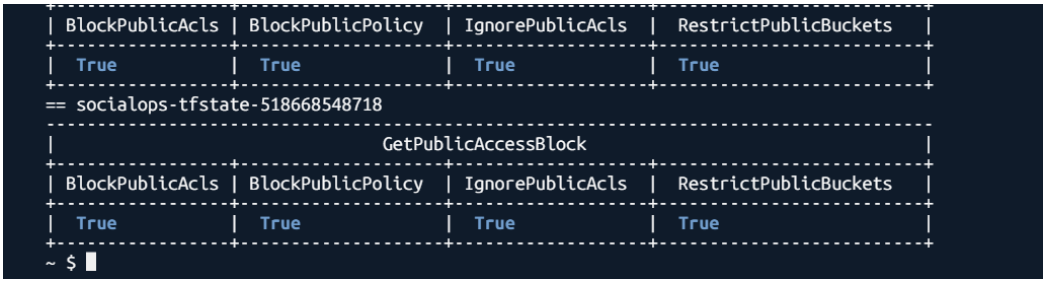


Figure A2 – Block Public Access: all four settings True on socialops-dev-assets (top table) and socialops-tfstate (bottom table).

Full CloudShell output:

```
$ for b in socialops-dev-assets-518668548718 socialops-tfstate-518668548718; do ...
== socialops-dev-assets-518668548718
| BlockPublicAcls | BlockPublicPolicy | IgnorePublicAcls | RestrictPublicBuckets |
|  True           |  True             |  True            |  True                 |
== socialops-tfstate-518668548718
| BlockPublicAcls | BlockPublicPolicy | IgnorePublicAcls | RestrictPublicBuckets |
|  True           |  True             |  True            |  True                 |
```

A3 & A4. IAM task role and Secrets Manager

CloudShell output of the API task definition check (names only, no values):

```
$ aws ecs describe-task-definition --task-definition socialops-dev-api --query ...
{
  "TaskRole": "arn:aws:iam::518668548718:role/socialops-dev-api-task",
  "Secrets": [ "DATABASE_URL" ],
  "PlainEnvNames": [ "LLM_MODEL_VISION", "AWS_REGION", "SQS_QUEUE_URL", "LLM_MODEL_TEXT",
                     "STORAGE_ROOT", "OLLAMA_BASE_URL", "STORAGE_BACKEND", "LLM_PROVIDER",
                     "LLM_MODEL_FAST", "REDIS_URL" ]
}
```

A5. No secrets or Terraform state in git

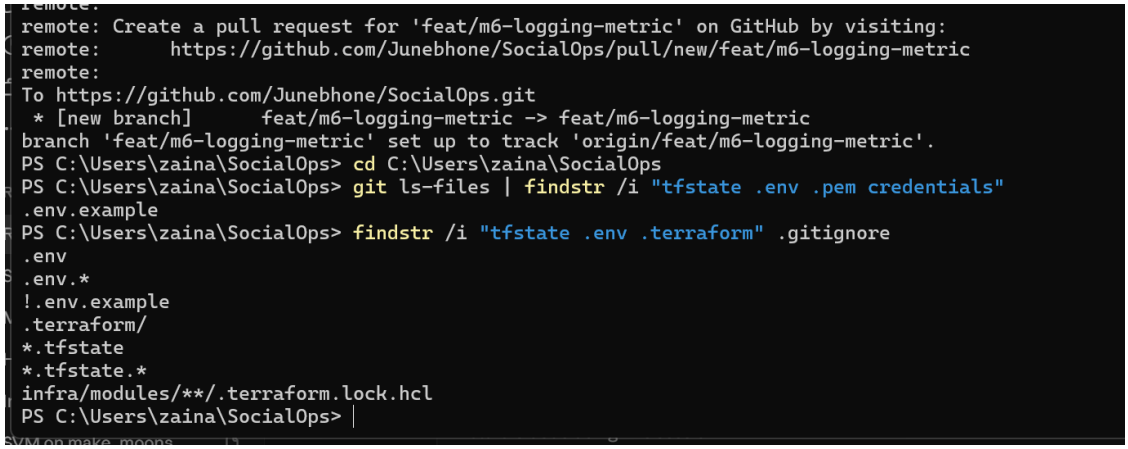


*Figure A5 – Only .env.example is tracked; .gitignore excludes .env, .terraform/ and *.tfstate.*

B. Logging and metric (live test)

B1. Metric filter definition

Namespace SocialOps/dev, metric Api5xxCount, value 1 per matching log line. Member 3's alarm reads Sum over 60 seconds, missing data treated as not breaching.

```
resource "aws_cloudwatch_log_metric_filter" "api_5xx" {
  name           = "${var.name}-api-5xx"
  log_group_name = var.api_log_group_name      # /ecs/socialops-dev/api
  pattern        = "{ $.status_code >= 500 }"
  metric_transformation {
    name      = "Api5xxCount"
    namespace = var.metric_namespace            # SocialOps/dev
    value     = "1"
    unit      = "Count"
  }
}
```

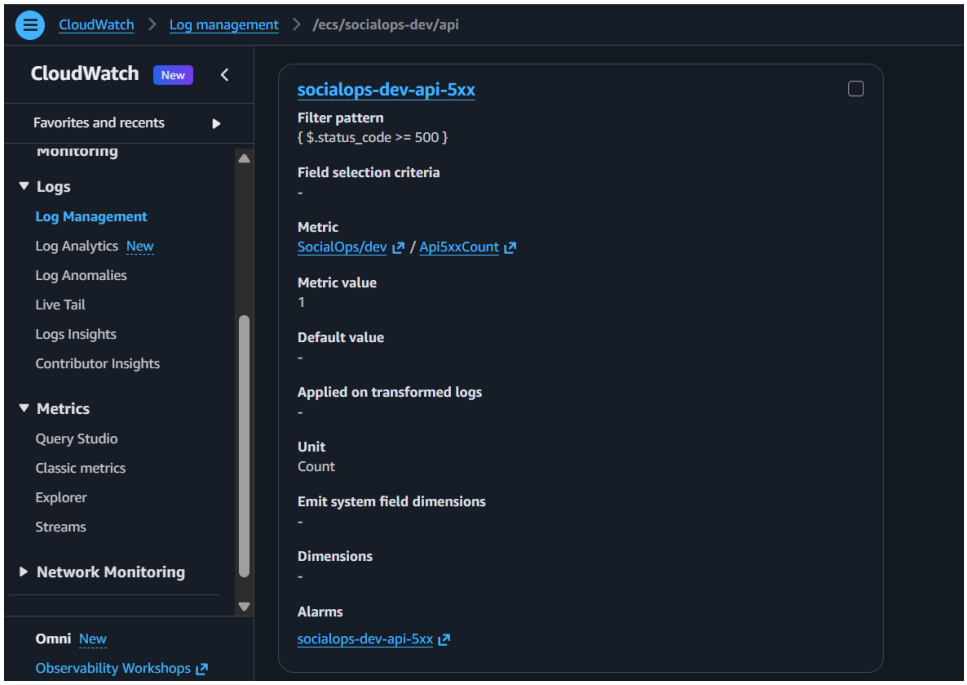


Figure B1 – Metric filter socialops-dev-api-5xx on /ecs/socialops-dev/api: pattern { $.status_code >= 500 }, metric SocialOps/dev / Api5xxCount, value 1, linked to alarm socialops-dev-api-5xx.

B2. Controlled error

```
~ $ aws ssm put-parameter --region us-east-1 --name /socialops-dev/enable-error-route --value true --overwrite
{
    "Version": 2,
    "Tier": "Standard"
}
~ $ curl -i https://api.socialops.website/debug/error
HTTP/2 500
date: Sun, 08 Nov 2026 23:52:15 GMT
content-type: application/json
content-length: 53
server: uvicorn
x-request-id: 25af8b47971440e3b4dfafd12437869e
vary: Origin

{"detail":"controlled error for the 5xx metric demo"}~ $
```

Figure B2 – Route switched on via SSM, then GET /debug/error returns HTTP 500 with x-request-id 25af8b47971440e3b4dfafd12437869e.

B3. JSON log entry for the controlled error

Found in Logs Insights on /ecs/socialops-dev/api with: fields @timestamp, @message | filter request_id = "<X-Request-ID>"



Figure B3a – Logs Insights on /ecs/socialops-dev/api filtered by request_id: exactly 1 of 1 records matched.

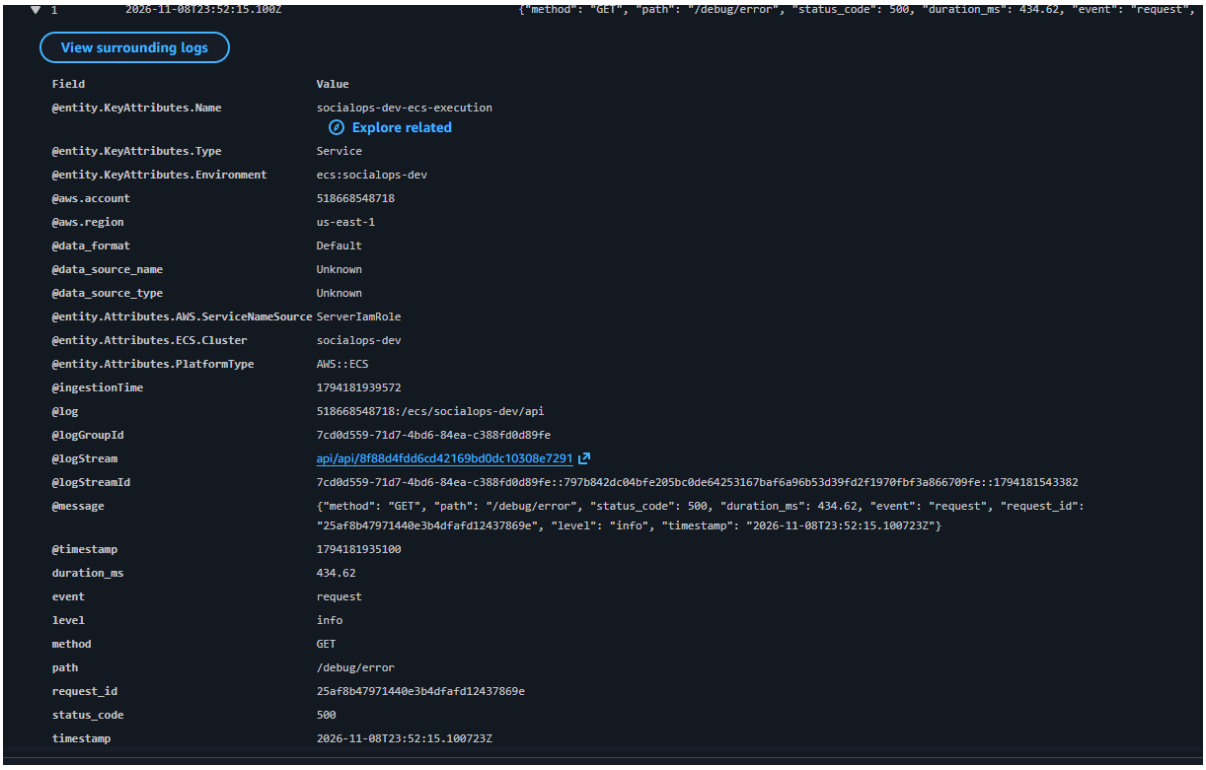


Figure B3b – The same entry expanded: CloudWatch parses it as JSON (event request, path /debug/error, status_code 500, request_id, duration_ms, timestamp).

B4. Metric count rises

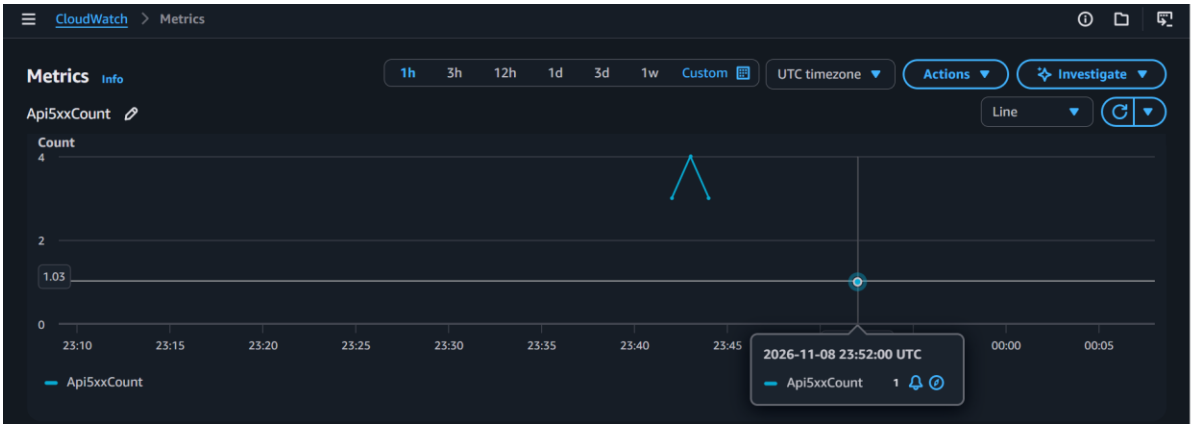


Figure B4 – SocialOps/dev Api5xxCount, Sum, 1-minute period: 1 at 23:52 UTC, the minute of the controlled error. The earlier peak near 23:43 is the team's rollback demo (failed health checks).

B5. Route switched off again



Figure B5 – SSM parameter set back to false; GET /debug/error now returns 404 Not Found, so the public cannot trigger the alarm.